COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.1 · Threat Actors

Mestre CyberSec · **Lesson 2.1 — Threat Actors** (10:23) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Quem ataca e POR QUÊ: nation-state (governo — espionagem/sabotagem, recursos enorme — APT); organized crime (lucro — ransomware, credential theft); hacktivist (ideologia — Anonymous); insider (dentro da casa — intencional ou descuidado); script kiddie (usa exploit pronto, volume)

💡 Key Exam Highlights & Critical Concepts

- APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo
- Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar
- Script kiddie: usa exploit pronto — volume, pouca sofisticação
- Insider: o maior risco por já estar DENTRO da confiança

🎯 Exam Tips & Typical CompTIA Scenarios

- 'motivated by political/social ideology' = hacktivist
- 'long-term, nation-state, persistent' = APT

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.1 — Threat Actors)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Threat Actor (Threat Actor) (N/A)

Any person or group that intentionally or accidentally causes harm to a system or organization; categorized by motivation, resources, and sophistication level.

⚠️ ***Exam Trap:*** *Gatilho: a prova SEMPRE dá a MOTIVAÇÃO e espera que você identifique o ator. Decore o mapeamento: dinheiro = organized crime, ideologia = hacktivist, política/militar = nation-state, dentro da empresa = insider, exploit pronto/volume = script kiddie.*

• Advanced Persistent Threat (APT)

A highly sophisticated, well-funded attacker—typically a nation-state—that maintains long-term, stealthy access to a target network to steal data or conduct espionage/sabotage.

⚠️ ***Exam Trap:*** *Gatilhos: 'long-term', 'persistent', 'nation-state', 'remains undetected for months/years', 'espionage'. Se a questão fala em ataque prolongado e oculto com muitos recursos, a resposta é APT — não organized crime nem script kiddie.*

• Nation-State Actor (N/A)

A government-sponsored attacker with enormous resources, advanced tooling, and zero-day exploitation capability, motivated by political, military, or espionage objectives.

⚠️ ***Exam Trap:*** *Gatilho: 'government-sponsored', 'political/military motivation', 'espionage', 'zero-day', 'highest sophistication'. Distinção-chave: nation-state = política/espionagem com recursos ilimitados; organized crime = lucro; hacktivist = ideologia.*

• Organized Crime (N/A)

A structured criminal group motivated primarily by financial gain that uses ransomware, credential theft, and fraud to monetize attacks, often operating as a service (Ransomware-as-a-Service).

⚠️ ***Exam Trap:*** *Gatilho: 'financial gain', 'profit', 'ransomware', 'stolen credentials for sale', 'criminal syndicate'. Se a motivação é DINHEIRO, marque organized crime — nunca hacktivist (ideologia) nem nation-state (política).*

• Hacktivist (N/A)

An attacker driven by political or social ideology who uses hacking techniques (defacement, DDoS, data leaks) to promote a cause or protest an organization; Anonymous is the classic example.

⚠️ ***Exam Trap:*** *Gatilho literal da prova: 'motivated by political or social ideology' = hacktivist. Se aparecer 'ideology', 'protest', 'cause' ou 'Anonymous', é hacktivist — não confunda com nation-state (política, mas patrocinado por governo).*

• Insider Threat (N/A)

A threat originating from someone inside the organization with legitimate access—employees, contractors, or partners—acting either maliciously (intentional data theft/sabotage) or unintentionally (negligence, shadow IT, falling for phishing).

⚠️ ***Exam Trap:*** *Gatilho: 'already has access', 'trusted employee', 'inside the organization'. É o MAIOR risco porque já está dentro do perímetro de confiança e pode contornar controles externos. Lembre: insider pode ser INTENCIONAL ou ACCIDENTAL.*

• Script Kiddie (Unskilled Attacker) (N/A)

A low-skill attacker who uses pre-built exploits, tools, and scripts written by others to launch attacks, generating high volume but low sophistication and no custom capability.

⚠️ ***Exam Trap:*** *Gatilhos: 'uses pre-made tools/exploits', 'no technical skill', 'high volume', 'downloaded attack kit'. Distinção-chave: script kiddie = volume e pouca sofisticação; APT = stealth de longo prazo e muita sofisticação.*

• Shadow IT (N/A)

Unauthorized hardware, software, or cloud services used by employees without IT approval, creating unmanaged attack surface and representing a common unintentional insider threat.

⚠️ ***Exam Trap:*** *Gatilho: 'employee installs/uses unapproved app or cloud service', 'no IT approval', 'bypasses security controls'. Se a questão aponta negligência interna SEM má intenção, pense em insider não intencional / shadow IT.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A defense contractor's SOC discovers that an adversary has maintained persistent access to engineering networks for 18 months. Investigators find zero-day exploits, custom RATs with multiple redundant C2 channels, and operational timing aligned with the target nation's business hours. The stolen data involves proprietary propulsion schematics. Which threat actor BEST matches this profile?

A) Organized crime syndicate focused on financial fraud

B) Nation-state advanced persistent threat (APT)

C) Hacktivist collective seeking publicity

D) Unskilled script kiddie using public exploits

QUESTION 2 · EXAM SCENARIO

A regional hospital network is paralyzed when ransomware encrypts EHR systems and exfiltrates patient records. The attackers used commodity LockBit-variant ransomware delivered via a phishing kit, demanded $4M in Monero, and posted a countdown timer on the leak site threatening to publish records if unpaid. Which threat actor profile BEST fits?

A) Nation-state APT performing espionage

B) Hacktivist group protesting healthcare policy

C) Organized cybercrime syndicate seeking profit

D) Disgruntled former hospital IT employee

QUESTION 3 · EXAM SCENARIO

Hours after a controversial court ruling on data privacy, a company's public website is defaced with ideological slogans and a 5GB customer database is posted to a pastebin accompanied by a political manifesto. The attackers used a well-documented SQL injection on an unpatched login form and made no ransom demand. Which threat actor is MOST likely responsible?

A) Organized crime group hunting for credit cards

B) Nation-state APT stealing strategic intelligence

C) Script kiddie seeking fun and notoriety

D) Hacktivist group pursuing ideological goals

QUESTION 4 · EXAM SCENARIO

A senior database administrator resigns under contentious circumstances. Two weeks later, the company's entire customer table appears for sale on a competitor's marketplace. Forensic review shows the DBA's privileged credentials were used from an unfamiliar geolocation during off-hours the night before the exit interview. Which threat actor category does this scenario BEST illustrate?

A) External advanced persistent threat

B) Hacktivist collective

C) Malicious insider

D) Organized crime recruiting externally

QUESTION 5 · EXAM SCENARIO

A financial analyst at an investment firm receives an email that appears to come from the CFO requesting an urgent wire transfer to a new international vendor for a confidential acquisition. The email uses display-name spoofing and a look-alike domain. The analyst wires $850,000 without performing out-of-band verification. Which threat actor category BEST describes the human element that enabled this loss?

A) Unintentional / careless insider

B) Hacktivist

C) Nation-state APT

D) Organized crime operator

QUESTION 6 · EXAM SCENARIO

A web hosting provider's IDS logs show tens of thousands of connection attempts from diverse IPs across multiple countries, all attempting to exploit CVE-2017-5638 (Apache Struts) — a four-year-old, well-publicized vulnerability. The payloads are identical copies of a public Metasploit module, and the source IPs are largely compromised IoT devices and open proxies. Which threat actor BEST describes this activity?

A) Nation-state APT conducting targeted espionage

B) Hacktivist group making a political statement

C) Script kiddie / unskilled attacker running automated tools

D) Organized crime group deploying custom malware

QUESTION 7 · EXAM SCENARIO

Threat intelligence indicates an adversary has been quietly monitoring a mining conglomerate's SCADA systems for 14 months. The actor's objectives appear to be strategic intelligence about rare-earth mineral extraction capabilities — there is no attempt at financial fraud, no public claims, and no ransom activity. The intrusion serves long-term geopolitical resource competition. Which threat actor category BEST matches these motivations and resources?

A) Hacktivist collective

B) Organized crime syndicate

C) Disgruntled insider

D) Nation-state actor

QUESTION 8 · EXAM SCENARIO

An incident-response team is profiling a threat actor and notes the following capability indicators: (1) possession of three previously undisclosed zero-day vulnerabilities in enterprise VPN software, (2) custom-built implants with anti-forensic and rootkit capabilities, (3) command-and-control infrastructure spanning compromised routers across three continents using double-hop techniques, and (4) tradecraft that consistently avoids detection for 12+ months. Which classification BEST applies?

A) Script kiddie

B) Insider threat

C) Hacktivist collective

D) Nation-state advanced persistent threat (APT)

QUESTION 9 · EXAM SCENARIO

During a routine cloud governance review, the CISO discovers that the marketing department has been using an unsanctioned SaaS customer-survey platform for two years to capture and store customer email addresses and partial payment data — completely outside IT and security review processes. No breach has occurred yet. Which risk classification BEST applies to this exposure?

A) Nation-state espionage vector

B) Hacktivist recruitment opportunity

C) Organized crime target

D) Shadow IT

QUESTION 10 · EXAM SCENARIO

A long-running investigation reveals an adversary that has dwelled in a financial-services network for over 14 months, using legitimate Windows utilities (PowerShell, WMI, PsExec) for lateral movement, exfiltrating small amounts of data weekly to avoid triggering DLP thresholds, and patiently pivoting through contractor networks to reach the true target. Which term BEST describes this adversary behavior?

A) Brute-force credential attack

B) Distributed denial-of-service campaign

C) Advanced Persistent Threat (APT)

D) Standalone zero-day exploitation event

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Nation-state advanced persistent threat (APT)

The hallmarks of a nation-state APT are present: (1) long dwell time measured in months/years, (2) zero-day vulnerabilities requiring significant R&D investment, (3) custom malware with resilient C2 infrastructure, (4) operational discipline aligned to the victim's timezone to blend with normal traffic, and (5) targeting of strategic intellectual property (propulsion designs) for geopolitical advantage. Organized crime seeks fast monetization; hacktivists seek visibility; script kiddies cannot produce zero-days or custom RATs.

Question 2: Option C — Organized cybercrime syndicate seeking profit

Organized cybercrime groups are characterized by: financial motivation, use of commodity Ransomware-as-a-Service (RaaS) like LockBit, cryptocurrency demands, double-extortion tactics (encrypt + threaten to leak), and phishing-as-initial-vector. Healthcare is a prime target due to critical-service urgency that pressures rapid payment. Nation-states don't typically extort hospitals; hacktivists want publicity not money; insiders usually lack the RaaS infrastructure and leak-site countdown mechanics.

Question 3: Option D — Hacktivist group pursuing ideological goals

Hacktivists are motivated by ideology rather than financial gain. Key indicators here: (1) timing directly tied to a political/legal event, (2) defacement and public data dump with a manifesto rather than monetization, (3) no ransom demand, and (4) targeting intended to embarrass the organization publicly. Organized crime would monetize the data; a nation-state would not announce itself via defacement; a script kiddie typically lacks the ideological framing and political motivation.

Question 4: Option C — Malicious insider

This is a textbook malicious insider scenario. Indicators: (1) trusted employee with privileged access, (2) timing correlated with a contentious departure, (3) abuse of legitimate credentials (no need for exploits), (4) direct financial benefit to a competitor, and (5) data exfiltration occurring during off-hours when monitoring is reduced. External APTs would not have valid internal credentials tied to a departing employee; hacktivists don't sell data to competitors; organized crime would not typically have direct placement in the organization.

Question 5: Option A — Unintentional / careless insider

The financial analyst is the victim of a Business Email Compromise (BEC) attack — but from a threat-actor-modeling perspective, the human who FAILED the organization is the unintentional/careless insider. They had the training, the tools, and the policy to verify the request but did not exercise due care. CompTIA explicitly categorizes insiders as either malicious (intentional) or unintentional (careless/negligent). This falls squarely into the unintentional insider category because no malicious intent exists — only a failure to follow verification procedures.

Question 6: Option C — Script kiddie / unskilled attacker running automated tools

Script kiddies leverage pre-built, publicly available exploitation tools (e.g., Metasploit, Shodan) without understanding the underlying vulnerability. Indicators here: (1) exploitation of an OLD, well-known CVE rather than fresh research, (2) use of a Metasploit module verbatim — no customization, (3) infrastructure consisting of compromised IoT devices and open proxies (typical botnet/scanner output), (4) high-volume opportunistic scanning rather than targeted reconnaissance, and (5) no evidence of post-exploitation sophistication. Nation-states, hacktivists running ideological ops, and organized crime all demonstrate significantly more sophistication and tailored tooling.

Question 7: Option D — Nation-state actor

Nation-state actors conduct long-term intelligence operations aligned with national strategic interests. Key indicators: (1) targeting of a sector tied to national resource security (rare earth minerals), (2) long dwell time measured in months/years, (3) focus on espionage rather than monetization, (4) lack of public attribution (hacktivists want credit), (5) no financial motive that organized crime would pursue, and (6) SCADA targeting typical of state-sponsored industrial espionage. The geopolitical framing of 'resource competition' is the defining clue.

Question 8: Option D — Nation-state advanced persistent threat (APT)

These capability indicators define a nation-state APT. Zero-day vulnerabilities require either massive R&D investment or acquisition from vulnerability brokers, both requiring nation-state-level funding. Custom implants with anti-forensic features require skilled developer teams. Multi-continent C2 with double-hop chaining requires significant operational infrastructure. Combined with long dwell time, this is the textbook capability profile of an APT. Script kiddies cannot produce zero-days or custom implants; insiders typically lack global C2 infrastructure; hacktivists rarely possess or need this level of operational tradecraft.

Question 9: Option D — Shadow IT

Shadow IT refers to IT systems, solutions, and devices deployed and used inside an organization without explicit organizational approval or visibility from the IT/security department. The marketing team's unsanctioned SaaS usage fits this definition precisely. Shadow IT creates risk because the systems bypass security controls, vendor assessments, data classification, encryption policies, and incident-response planning. CompTIA includes Shadow IT in the threat-actors domain because the unauthorized systems become soft targets for any external actor (organized crime, APT, hacktivist) and frequently serve as data-exfiltration or pivot points.

Question 10: Option C — Advanced Persistent Threat (APT)

Advanced Persistent Threat (APT) is defined by three attributes: (A)dvanced — uses sophisticated techniques including living-off-the-land binaries (LOLBins) to evade detection, (P)ersistent — maintains long-term access (months/years) rather than quick-hit exploitation, and (T)hreat — has organized resources and a defined objective. Indicators here: multi-month dwell time, LOLBin tradecraft to blend with admin activity, low-and-slow exfiltration to avoid DLP, and patient supply-chain pivoting through contractors. Brute-force, DDoS, and a single zero-day event are all point-in-time attacks — not persistent campaigns.